

Open Source Compliance in the Enterprise: Why Have an Open Source Compliance Program?

Open Source Compliance in the Enterprise: Why Have an Open Source Compliance Program?

Created on 2017-02-01 04:46

Published on 2017-02-02 17:24



Traditionally, platforms and software stacks were implemented using proprietary software, and consisted of various software building blocks that originated as a result of internal development or via third-party software providers with negotiated licensing terms. The business environment was predictable and companies mitigated potential risks through license and contract negotiations with the software vendors. It was very easy to know who was the provider for every software component.



Figure 1 illustrates the major building blocks of a traditional hardware and software platform. Over time, companies started to incorporate open source software into their platforms and software stacks due to the advantages it offers. The reasons varied from product to product, but the common theme across industries was that open source components provided compelling features out of the box, there were meaningful economies to be gained through distributed development that resulted in a faster time-to-market, and they offered a new-found ability to customize the source code. As a result, a new multi- source development model began to emerge.

Under the new model, a product could now have any combination of:

- Proprietary code, developed by the company building the product/service
- Proprietary code, originally developed by the company under an open source license in the process of integrating and deploying open source components, but was not contributed back to the upstream open source project
- Third-party commercial code, developed by third-party software providers and received by the company building the product/service under a commercial license
- Open source code, developed by the open source community and received

by the company building the product/service under an open source license.

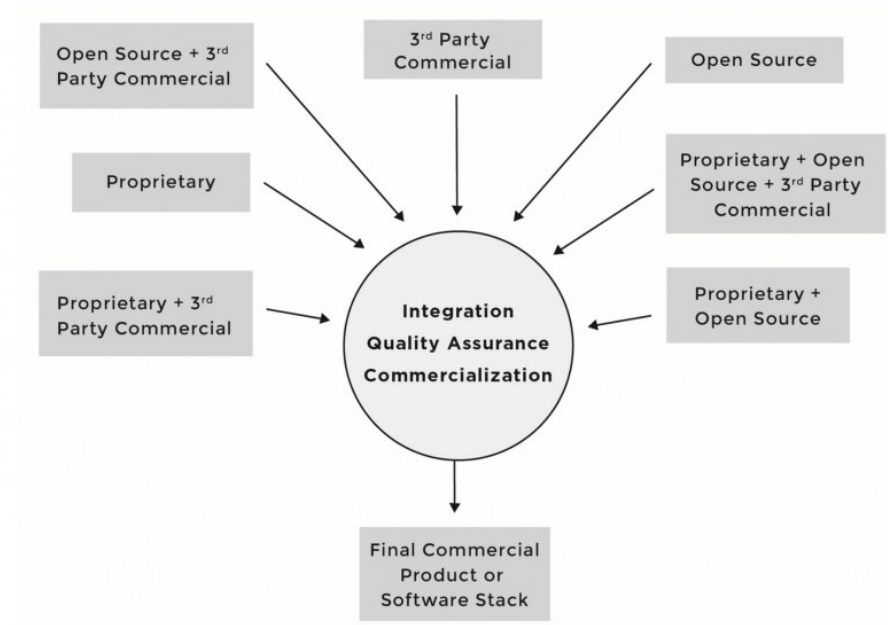


Figure 2 illustrates the multi-source development model and the various combinations of sources for incoming source code. Under this development model, software components can consist of source code originating from any number of different sources and be licensed under different licenses; for instance, software component A can include proprietary source code in addition to third-party proprietary source code, while software component B can include proprietary source code in addition to source code from an open source project. As the number of open source software components grew in what were once straightforward proprietary software stacks, the business environment diverged from familiar territory and corporate comfort zones.

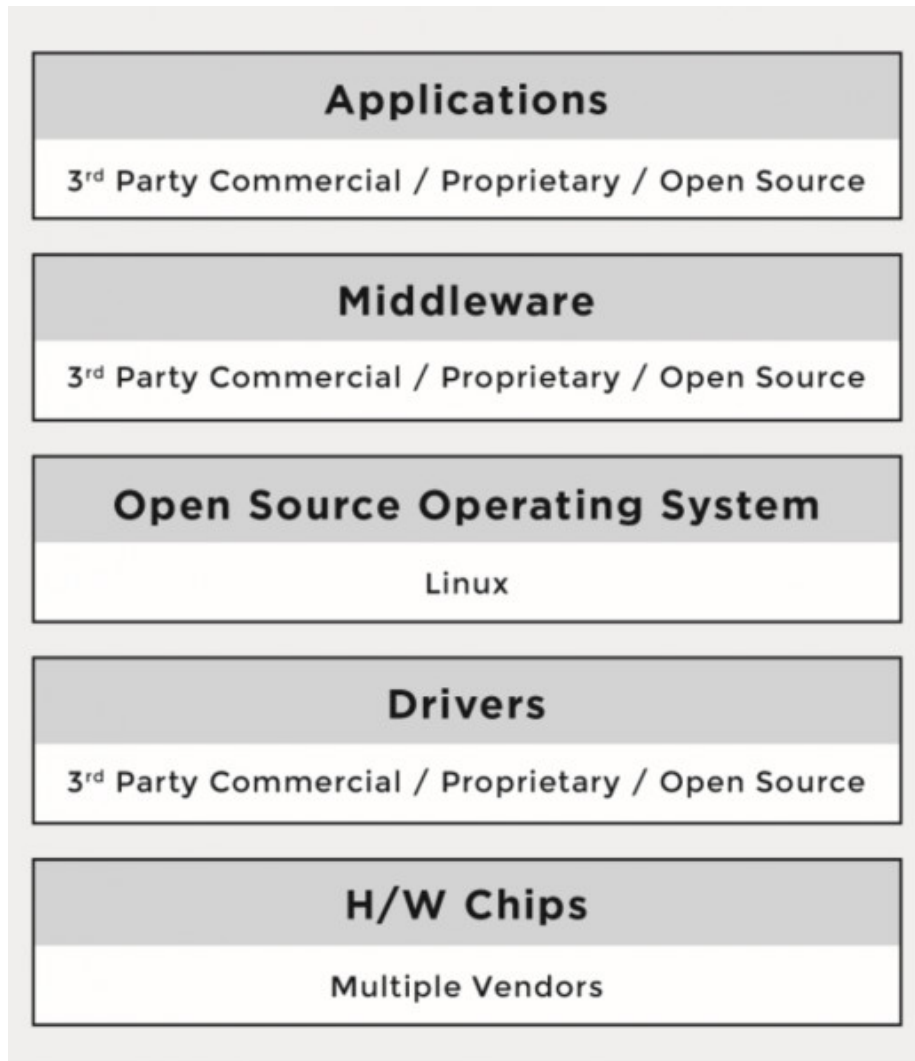


Figure 3 illustrates the adoption of open source software throughout the various levels of a given platform or software stack. One of the major differences between the proprietary and the multi-source development models has been that the licenses of open source software are not negotiated. There are no contracts to sign with the software providers (i.e., open source developers or projects). Rather, the individuals who initiate the project chose a given open source license, and once a project reaches a certain scale, the licenses are virtually impossible to change.

When using the multi-source development model, companies must understand the implications of tens of different licenses (and combinations of licenses) coming from hundreds or even thousands of licensors or contributors (copyright hold-

ers). As a result, the risks that companies previously managed through company-to-company license and agreement negotiations are now managed through robust compliance programs and careful engineering practices.

In a follow up post, we'll cover the benefits of open source compliance and the risks that companies face when they fail to comply.

The following is adapted from "Open Source Compliance in the Enterprise" published by The Linux Foundation (free e-book download), a complete guide to creating compliance processes and policies for your organization.

Original post appeared on Linux.com.
